面试题一：

在AI发展得很快，AI能在极短时间内挖出信息系统基础设施的0 day, 信息系统基础设施被攻击的风险暴露缩短在极小的时间内被利用。请回答各大安全厂商如何应对这种情况发生？作为信息系统基础设施安全建设的你又是如何规划处理这种新的趋势的发生呢?

安全厂商的应对措施：

一、部署AI漏洞挖掘系统

部署研发AI漏洞挖掘系统（ARTEX、CyberStrikeAI、AI 安全渗透规则）, 在攻击者之前扫荡自身和客户的信息系统基础设施。关键在于，挖出的漏洞不再排队等补丁，而是立即转化为**虚拟补丁/前置防护规则**，直接推送到防火墙边界。

二、漏洞情报前置共享

在漏洞公开前就将情报转化为网络层防护规则，分发给受保护的节点。

三、根因类别批量免疫

AI能以小时级产出大量同源变种漏洞时，逐条打补丁在数学上已不可能。需要按**漏洞根因模式**（如内存漏洞）进行批量虚拟封堵，而非针对单个CVE写规则。

安全建设规划措施：

一、影响范围预设

这个0 day 引爆后，最多能炸到哪？哪些内部资产与其之间存在**非必要可达路径**，然后提前切断。例如，一个面向公网的Web服务即使被打穿，它也不能直接横向访问核心数据库，这条路径在 0day 出现之前就已经被默认封死。**当攻击者发现某个目标"硬化到难以下手"时，会转向更容易的目标。我的目标是让我的基础设施在AI扫描器眼中成为"性价比最低的那个"。**

二、可逆性补丁策略

传统打补丁怕搞坏业务，所以测试周期长，暴露窗口大。对于AI标记为高危且已被利用的漏洞，**跳过漫长的稳定性测试，直接部署带自动回滚的补丁。**需要基础设施具备不可变镜像（容器镜像 + 镜像仓库版本化）或蓝绿部署能力（蓝=当前运行，绿=新版本 负载均衡/网关层：Nginx 后端指向蓝组或绿组，upstream 配置或权重）。

三、AI 代码审计

AI 发现的漏洞中92%不是传统模糊测试能覆盖的语义/架构缺陷，而是集中在业务逻辑层。代码合并前就用前沿模型（AI 安全代码审计规则 **cloudflare/security-audit-skill**）模拟攻击者视角审计业务逻辑,把最容易被AI批量发现的那类模式性缺陷清除掉。

四、最小化权限

0 day 利用成功后，攻击者第一件事通常是提权或横向移动。从“追着堵每一个0day”转移到“系统性地消除可达性和权限冗余”上，让攻击即使发生，也找不到足以造成系统性崩塌的路径。